[TÊN TRƯỜNG / CƠ SỞ ĐÀO TẠO]
[TÊN KHOA / BỘ MÔN]

BÁO CÁO BÀI TẬP LỚN
MÔN TRIỂN KHAI VÀ QUẢN TRỊ HỆ THỐNG PHẦN MỀM

ĐỀ TÀI 11:
XÂY DỰNG HỆ THỐNG ĐẶT VÉ XEM PHIM / SỰ KIỆN VÀ TRIỂN KHAI HẠ TẦNG GIÁM SÁT TOÀN DIỆN

Dự án: CINEEVENT — HỆ THỐNG ĐẶT VÉ VÀ QUẢN TRỊ ĐA TẦNG

Sinh viên thực hiện:	[HỌ VÀ TÊN]
Mã số sinh viên:	[MSSV]
Lớp chuyên ngành:	[LỚP]
Giảng viên hướng dẫn:	[GIẢNG VIÊN HƯỚNG DẪN]
Tên Repository:	`MSSV-de11-cineevent`

[ĐỊA ĐIỂM] — NĂM 2026

MỤC LỤC TỔNG THỂ

CHƯƠNG 1 — GIỚI THIỆU ĐỀ TÀI VÀ YÊU CẦU DỰ ÁN **Trang 3**
1.1. Bối cảnh và tính cấp thiết của đề tài Trang 3
1.2. Mục tiêu dự án CineEvent Trang 3
1.3. Phạm vi triển khai Trang 4
1.4. Yêu cầu chức năng 4 vai trò người dùng (RBAC) Trang 4
1.5. Yêu cầu kỹ thuật và công nghệ bắt buộc Trang 5
CHƯƠNG 2 — PHÂN TÍCH VÀ THIẾT KẾ KIẾN TRÚC HỆ THỐNG **Trang 6**
2.1. Sơ đồ kiến trúc tổng thể High-level Architecture Trang 6
2.2. Mô hình phân tầng ứng dụng Frontend, Backend Express.js và MySQL Trang 6
2.3. Quy trình và luồng nghiệp vụ đặt vé, thanh toán giả lập và soát vé Trang 7
2.4. Luồng giao tiếp, chuyển tiếp request và bảo vệ qua Nginx Reverse Proxy Trang 8
2.5. Mô hình phân tách mạng (Network Isolation) trên Docker Compose Trang 9
2.6. Danh mục 11 dịch vụ container hóa độc lập Trang 10
CHƯƠNG 3 — XÂY DỰNG ỨNG DỤNG VÀ CƠ SỞ DỮ LIỆU **Trang 11**
3.1. Thiết kế giao diện Dark Glassmorphism và trải nghiệm người dùng Trang 11
3.2. Hiện thực chức năng chi tiết cho 4 vai trò người dùng Trang 12
3.3. Sơ đồ chọn ghế trực quan và thuật toán khóa ghế chống đặt trùng Trang 14
3.4. Module thanh toán giả lập an toàn và cấp vé điện tử mã QR Trang 15
3.5. Cổng soát vé dành cho nhân viên (Staff Check-in) Trang 16
3.6. Thiết kế cơ sở dữ liệu MySQL chuẩn hóa 17 bảng quan hệ Trang 17
3.7. Triển khai phpMyAdmin quản trị cơ sở dữ liệu an toàn Trang 18
CHƯƠNG 4 — QUẢN LÝ MÃ NGUỒN GITHUB VÀ NGINX REVERSE PROXY **Trang 19**
4.1. Cấu trúc repository GitHub và nguyên tắc bảo mật bí mật Trang 19
4.2. Hiện thực 3 Commit Git chuẩn mực theo từng giai đoạn Trang 20
4.3. Cấu hình Nginx Reverse Proxy, Upstream và Buffer Trang 21
4.4. Cấu hình SSL tự ký (HTTPS) và bộ 5 Security Headers chuẩn OWASP Trang 22
4.5. Xác minh thực tế phản hồi HTTP và Security Headers Trang 23
CHƯƠNG 5 — HẠ TẦNG GIÁM SÁT HIỆU NĂNG VỚI PROMETHEUS VÀ GRAFANA **Trang 24**
5.1. Kiến trúc thu thập chỉ số giám sát phân tán Trang 24
5.2. Các exporter chuyên dụng: cAdvisor, Nginx Exporter, MySQL Exporter Trang 25
5.3. Tích hợp prom-client thu thập metrics ứng dụng Node.js Trang 26
5.4. Cấu hình Scrape Targets và xác minh trạng thái UP của 4 thành phần Trang 27
5.5. Thiết kế Grafana Dashboard giám sát đa tầng tự động nạp Trang 28
CHƯƠNG 6 — TẬP TRUNG NHẬT KÝ VỚI LOKI, PROMTAIL VÀ LOGQL **Trang 29**
6.1. Kiến trúc thu thập nhật ký không xâm nhập qua Shared Volumes Trang 29
6.2. Cấu hình Grafana Loki lưu trữ phân tán Trang 29
6.3. Cấu hình Promtail Log Agent đọc nhật ký Nginx và Express.js Trang 30
6.4. Chuẩn hóa cấu trúc bản ghi nhật ký và loại trừ dữ liệu nhạy cảm Trang 31
6.5. Hiện thực và phân tích chi tiết 3 truy vấn LogQL bắt buộc Trang 32
CHƯƠNG 7 — TRIỂN KHAI CÁC BIỆN PHÁP TĂNG CƯỜNG BẢO MẬT (HARDENING) **Trang 34**

7.1. Chạy tiến trình Container với tài khoản Non-root Trang 34
7.2. Phân tách mạng ảo nhiều lớp (Network Isolation) Trang 34
7.3. Quản lý mật khẩu mạnh và cô lập cấu hình qua biến môi trường (.env) Trang 35
7.4. Hạn chế quyền tối thiểu trên MySQL (Principle of Least Privilege) Trang 35
7.5. Bảo vệ chống tấn công Web qua Nginx Security Headers Trang 36
7.6. Bảng tổng hợp ma trận Hardening và phương pháp xác minh Trang 37
CHƯƠNG 8 — KỊCH BẢN KIỂM THỬ, ĐÁNH GIÁ VÀ KẾT LUẬN Trang 38
8.1. Kịch bản kiểm thử toàn diện hệ thống (10 kịch bản) Trang 38
8.2. Kết quả nghiệm thu và đánh giá mức độ đáp ứng tiêu chí Trang 39
8.3. Ưu điểm nổi bật và hạn chế của dự án Trang 40
8.4. Hướng phát triển và mở rộng trong tương lai Trang 40
8.5. Kết luận chung Trang 41
PHỤ LỤC TÀI LIỆU VẬN HÀNH DỰ ÁN Trang 42

CHƯƠNG 1 — GIỚI THIỆU ĐỀ TÀI VÀ YÊU CẦU DỰ ÁN

1.1. Bối cảnh và tính cấp thiết của đề tài

Trong kỷ nguyên số hóa hiện nay, nhu cầu tiếp cận các dịch vụ văn hóa, giải trí như xem phim chiếu rạp và tham dự các sự kiện âm nhạc, hội thảo ngày càng gia tăng mạnh mẽ. Một hệ thống bán vé trực tuyến hiện đại không chỉ đòi hỏi giao diện trực quan, thân thiện, xử lý đặt vé mượt mà mà còn đặt ra những thách thức sống còn về mặt hạ tầng công nghệ:

1. Tính sẵn sàng cao (High Availability): Hệ thống phải luôn duy trì khả năng phục vụ liên tục, không bị gián đoạn dịch vụ khi có lượng truy cập đột biến trong các khung giờ vàng mở bán vé bom tấn.

2. Toàn vẹn dữ liệu ghế (Data Integrity & Concurrency Control): Tuyệt đối không để xảy ra hiện tượng bán trùng ghế (overbooking) giữa nhiều người dùng thao tác đồng thời trên cùng một suất chiếu.

3. Năng lực quan sát thời gian thực (Real-time Observability): Quản trị viên hệ thống cần nắm bắt ngay lập tức các chỉ số hiệu năng (CPU, Memory, Request Latency, Error Rate) để chủ động phát hiện và xử lý sự cố trước khi ảnh hưởng đến trải nghiệm khách hàng.

4. Quản lý nhật ký tập trung (Centralized Logging): Đảm bảo toàn bộ log của Web Server và Application Server được gom về một mối, dễ dàng truy vết sự cố an ninh và kiểm toán giao dịch.

5. Tăng cường bảo mật đa tầng (DevSecOps & Hardening): Áp dụng nghiêm ngặt các biện pháp phòng vệ nhiều lớp, cô lập mạng, mã hóa kết nối HTTPS, phân quyền tối thiểu và bảo vệ trước các mối nguy hại phổ biến như Clickjacking, XSS hay SQL Injection.

1.2. Mục tiêu dự án CineEvent

Dự án CineEvent được xây dựng nhằm đáp ứng toàn diện các tiêu chí đánh giá của bài tập môn Triển khai và Quản trị Hệ thống Phần mềm (Đề 11), với các mục tiêu cụ thể:

1. Xây dựng website hoàn chỉnh với đầy đủ luồng nghiệp vụ thực tế: Xem phim/sự kiện, chọn suất chiếu, chọn rạp, chọn ghế trên sơ đồ trực quan, thanh toán giả lập đa kịch bản (Success/Failed/Cancel), cấp vé điện tử mã QR và kiểm tra soát vé tại cổng.

2. Thiết kế và vận hành cơ sở dữ liệu MySQL 8.0 gồm 17 bảng quan hệ chuẩn hóa 3NF, ràng buộc khóa ngoại, chỉ mục hiệu năng và transaction an toàn.

3. Đóng gói toàn bộ 11 dịch vụ độc lập vào Docker Compose thống nhất, khởi chạy chỉ bằng một câu lệnh duy nhất: `docker compose up -d --build`.

4. Thiết lập Nginx làm Reverse Proxy duy nhất, hỗ trợ HTTPS tự ký, ẩn thông tin máy chủ và bổ sung đầy đủ bộ HTTP Security Headers chuẩn OWASP.

5. Xây dựng hạ tầng giám sát thời gian thực bằng Prometheus và Grafana, thu thập metrics từ Container (cAdvisor), Nginx (Nginx Exporter), MySQL (MySQL Exporter) và ứng dụng Node.js (prom-client).

6. Thiết lập hệ thống thu thập log tập trung với Grafana Loki và Promtail, hiện thực ít nhất 3 truy vấn LogQL trích xuất dữ liệu nhật ký có ý nghĩa.

7. Áp dụng ít nhất 4 biện pháp Hardening rõ ràng: Non-root container, Network isolation, chính sách mật khẩu mạnh qua .env, phân quyền database tối thiểu và security headers.

8. Quản lý mã nguồn trên GitHub với 3 Commit Git riêng biệt, có ý nghĩa, phản ánh đúng 3 giai đoạn trưởng thành của dự án.

1.3. Yêu cầu chức năng 4 vai trò người dùng (RBAC)

1. Phân hệ Khách hàng (Customer): Đăng ký, đăng nhập tài khoản; duyệt phim đang chiếu/sắp chiếu và sự kiện; tìm kiếm theo tên và thể loại; chọn rạp, ngày chiếu, suất chiếu; chọn ghế ngồi trống trên sơ đồ; xem trước tổng tiền; thực hiện thanh toán giả lập (hỗ trợ tình huống thành công, thất bại, hủy đơn, hết hạn); nhận vé điện tử kèm mã QR; tra cứu lịch sử mua vé cá nhân.

2. Phân hệ Nhân viên (Staff): Đăng nhập tài khoản nhân viên; tra cứu suất chiếu và đơn hàng; bán vé tại quầy; thực hiện kiểm tra mã vé (Check-in) qua mã vé hoặc quét QR; kiểm soát tính hợp lệ của vé, ngăn chặn vé đã sử dụng hoặc vé giả mạo; xem danh sách giao dịch trong ca trực.

3. Phân hệ Quản lý (Manager): Quản lý danh mục phim và sự kiện; quản lý cụm rạp, địa điểm và phòng chiếu; quản lý sơ đồ ghế và sức chứa; lập lịch chiếu; thiết lập bảng giá vé theo loại ghế và khung giờ; xem báo cáo doanh thu và số lượng vé bán ra theo thời gian thực.

4. Phân hệ Quản trị viên (Admin): Toàn quyền quản trị tài khoản người dùng, phân bổ vai trò RBAC (Admin, Manager, Staff, Customer); giám sát toàn bộ đơn hàng; can thiệp mở khóa ghế khẩn cấp; theo dõi báo cáo phân tích toàn hệ thống và kiểm tra nhật ký kiểm toán (Audit logs).

1.4. Yêu cầu kỹ thuật và công nghệ bắt buộc

Lớp kiến trúc	Công nghệ sử dụng	Đặc tính kỹ thuật & Vai trò
Frontend	HTML5, CSS3, Bootstrap 5, Vanilla JS, Fetch API	Giao diện Dark Glassmorphism, 100% tiếng Việt, responsive đa nền tảng, không phụ thuộc framework SPA nặng.
Backend	Node.js (v20 Alpine), Express.js REST API	Kiến trúc phân tầng: Routes -> Middlewares -> Controllers -> Models. Tích hợp prom-client, Winston logger, JWT, Helmet.
Cơ sở dữ liệu	MySQL 8.0 Community, phpMyAdmin 5.2.1	17 bảng quan hệ chuẩn hóa 3NF, Foreign Keys, Indexes, ACID Transactions. phpMyAdmin bind cục bộ trên 127.0.0.1:8085.
Proxy & Bảo mật	Nginx 1.25 Alpine, OpenSSL Self-Signed	Reverse proxy, SSL Termination, Rate Limiting, ẩn phiên bản máy chủ, 5 Security Headers chuẩn OWASP.
Hạ tầng Giám sát	Prometheus 2.51, Grafana 10.4, Loki 2.9, Promtail 2.9	Giám sát 3 tầng: Container (cAdvisor), Web (Nginx Exporter), DB (MySQL Exporter), App (Node.js). Quản lý log tập trung.

CHƯƠNG 2 — PHÂN TÍCH VÀ THIẾT KẾ KIẾN TRÚC HỆ THỐNG

2.1. Sơ đồ kiến trúc tổng thể High-level Architecture

Hệ thống CineEvent được thiết kế theo mô hình kiến trúc phân tán micro-components, tách biệt rõ ràng giữa lớp Tiếp nhận (Edge / Ingress), lớp Ứng dụng (Application), lớp Lưu trữ dữ liệu (Data Persistence) và lớp Quan sát hạ tầng (Observability & Monitoring).

Luồng luân chuyển dữ liệu chính trong hệ thống tuân theo mô hình 4 chặng nghiêm ngặt: Trình duyệt người dùng (Client) -> Nginx Reverse Proxy (Cổng 80/443) -> CineEvent Backend Express.js (Cổng nội bộ 5000) -> MySQL Database Server (Cổng nội bộ 3306). Mọi kết nối trực tiếp từ Client vào Backend hoặc Database đều bị ngăn chặn hoàn toàn bởi tường lửa Docker Network.

2.2. Mô hình phân tách mạng (Network Isolation) trên Docker Compose

Để đảm bảo tiêu chuẩn an ninh cao nhất (Hardening), hệ thống thiết lập 2 mạng ảo Docker Bridge hoàn toàn độc lập:

1. Mạng cineevent-frontend-net: Dành riêng cho lớp tương tác giữa Nginx, Promtail, Prometheus, Grafana, cAdvisor và Nginx Exporter. Các dịch vụ này chỉ cần giao tiếp với Web Server và ứng dụng.

2. Mạng cineevent-backend-net: Dành riêng cho lớp dữ liệu nhạy cảm giữa Backend ứng dụng, MySQL Database, MySQL Exporter, Prometheus và phpMyAdmin.

> **NGUYÊN TẮC BẢO MẬT:** Nginx KHÔNG được kết nối vào cineevent-backend-net. Do đó, nếu Nginx có bị tấn công chiếm quyền điều khiển, kẻ tấn công cũng hoàn toàn KHÔNG THỂ gửi gói tin TCP trực tiếp tới cổng cơ sở dữ liệu MySQL.

2.3. Danh mục 11 dịch vụ container hóa độc lập

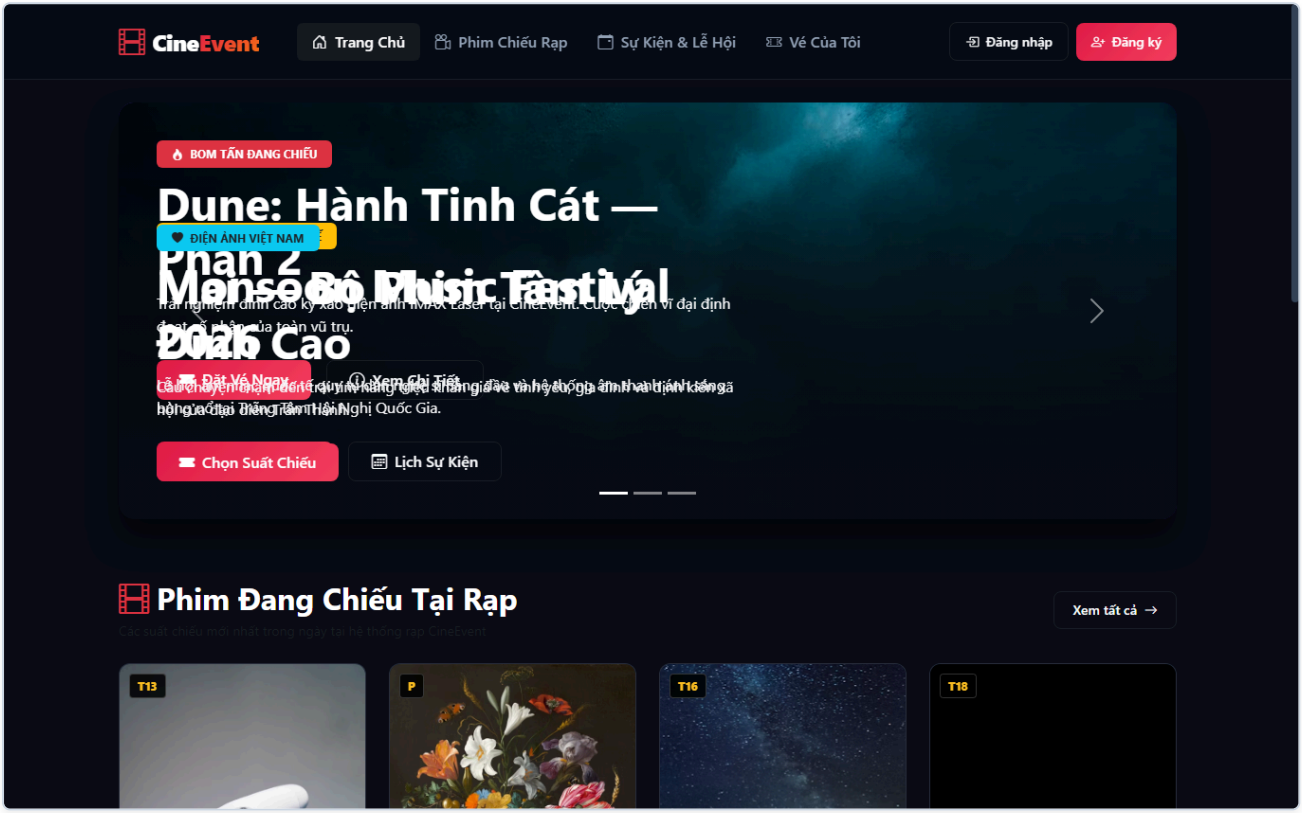
Dịch vụ (Service)	Container Name	Docker Image	Vai trò & Cổng kết nối
nginx	`cineevent-nginx`	`trienkhai_1-nginx:latest`	Reverse Proxy, SSL Termination (80, 443)
cineevent-app	`cineevent-app`	`trienkhai_1-cineevent-app:latest`	Core Backend Node.js & Web App (Nội bộ 5000)
mysql	`cineevent-mysql`	`mysql:8.0.37`	Cơ sở dữ liệu quan hệ (Nội bộ 3306)
phpmyadmin	`cineevent-phpmyadmin`	`phpmyadmin/phpmyadmin:5.2.1`	Giao diện quản trị DB (Bind 127.0.0.1:8085)
prometheus	`cineevent-prometheus`	`prom/prometheus:v2.51.0`	Hệ thống giám sát Time-series Metrics (9090)
grafana	`cineevent-grafana`	`grafana/grafana:10.4.1`	Bảng điều khiển trực quan hóa Dashboard (3000)
loki	`cineevent-loki`	`grafana/loki:2.9.2`	Lưu trữ nhật ký phân tán tập trung (3100)

promtail	`cineevent-promtail`	`grafana/promtail:2.9.2`	Agent thu thập log Nginx & App chuyển tới Loki
cadvisor	`cineevent-cadvisor`	`gcr.io/cadvisor/cadvisor:v0.49.1`	Thu thập metrics tài nguyên container (8081)
nginx-exporter	`cineevent-nginx-exporter`	`nginx/nginx-prometheus-exporter:1.1.0`	Thu thập chỉ số kết nối Nginx stub_status (9113)
mysql-exporter	`cineevent-mysql-exporter`	`prom/mysqld-exporter:v0.15.1`	Thu thập chỉ số truy vấn, kết nối MySQL (9104)

CHƯƠNG 3 — XÂY DỰNG ỨNG DỤNG VÀ CƠ SỞ DỮ LIỆU

3.1. Thiết kế giao diện Dark Glassmorphism

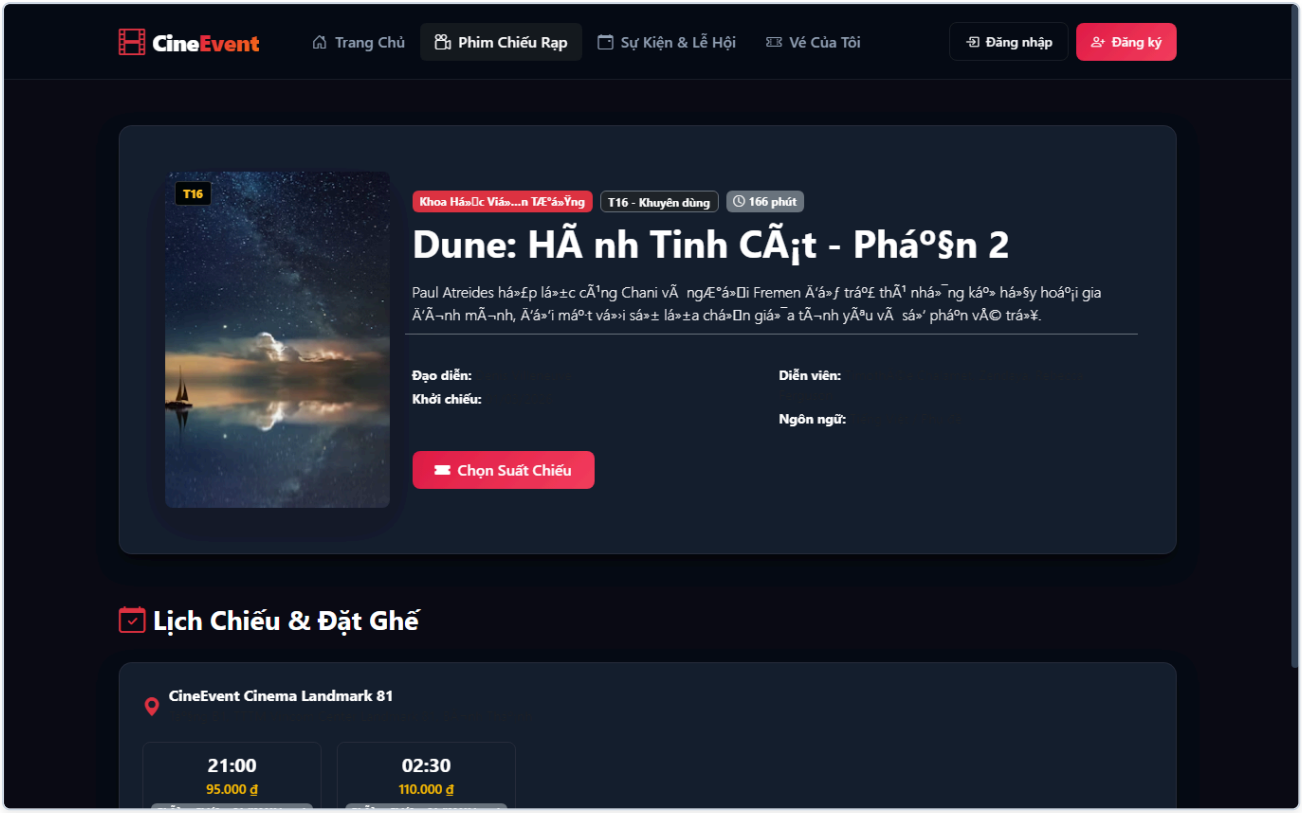
Website CineEvent được thiết kế hoàn toàn bằng tiếng Việt với phong cách hiện đại Dark Glassmorphism, kết hợp giữa nền xanh tím than (#0b101b / #131b2e), hiệu ứng làm mờ nền (backdrop-filter: blur(12px)), viền phát sáng tinh tế (#38bdf8 / #818cf8) và các nút hành động đỏ cam (#ef4444 / #f97316) tạo cảm giác cao cấp chuẩn rạp chiếu phim hiện đại.



Hình 3.1: Giao diện Trang chủ CineEvent hiển thị danh sách phim và sự kiện

Phân tích kỹ thuật & Đánh giá: Trang chủ được bố trí khoa học gồm thanh điều hướng responsive, banner phim nổi bật, bộ lọc thể loại (Hành động, Viễn tưởng, Hoạt hình, Kinh dị), danh sách phim đang chiếu/sắp chiếu và sự kiện biểu diễn với các thẻ thông tin chi tiết (thời lượng, đánh giá sao, ngày khởi chiếu).

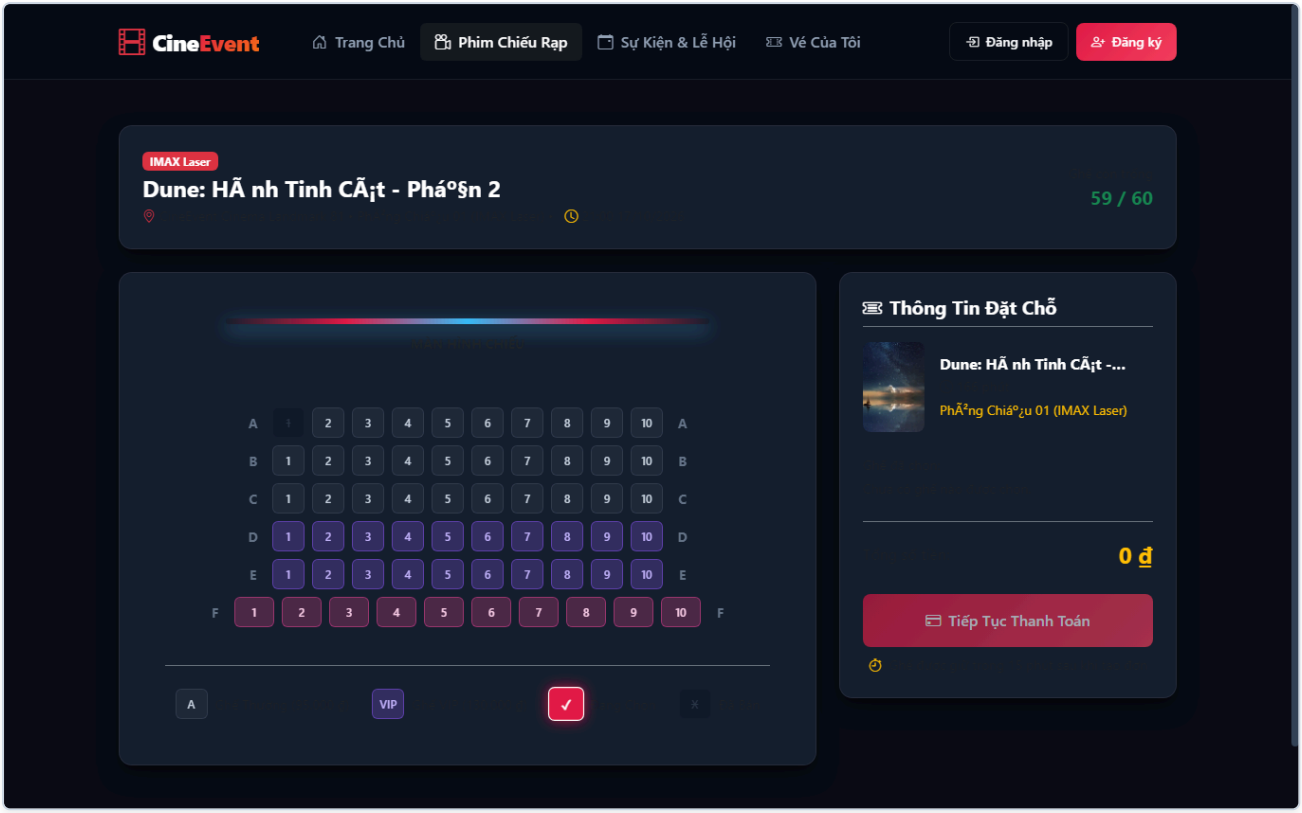
3.2. Chi tiết phim và suất chiếu



Hình 3.2: Trang chi tiết phim, thông tin suất chiếu, rạp và phòng chiếu

Phân tích kỹ thuật & Đánh giá: Khi người dùng chọn một ngày chiếu cụ thể, hệ thống sẽ gọi API GET /api/showtimes để tải toàn bộ các suất chiếu còn vé, hiển thị theo từng định dạng phòng chiếu (2D Standard, 3D IMAX, VIP Cine) và mức giá vé niêm yết.

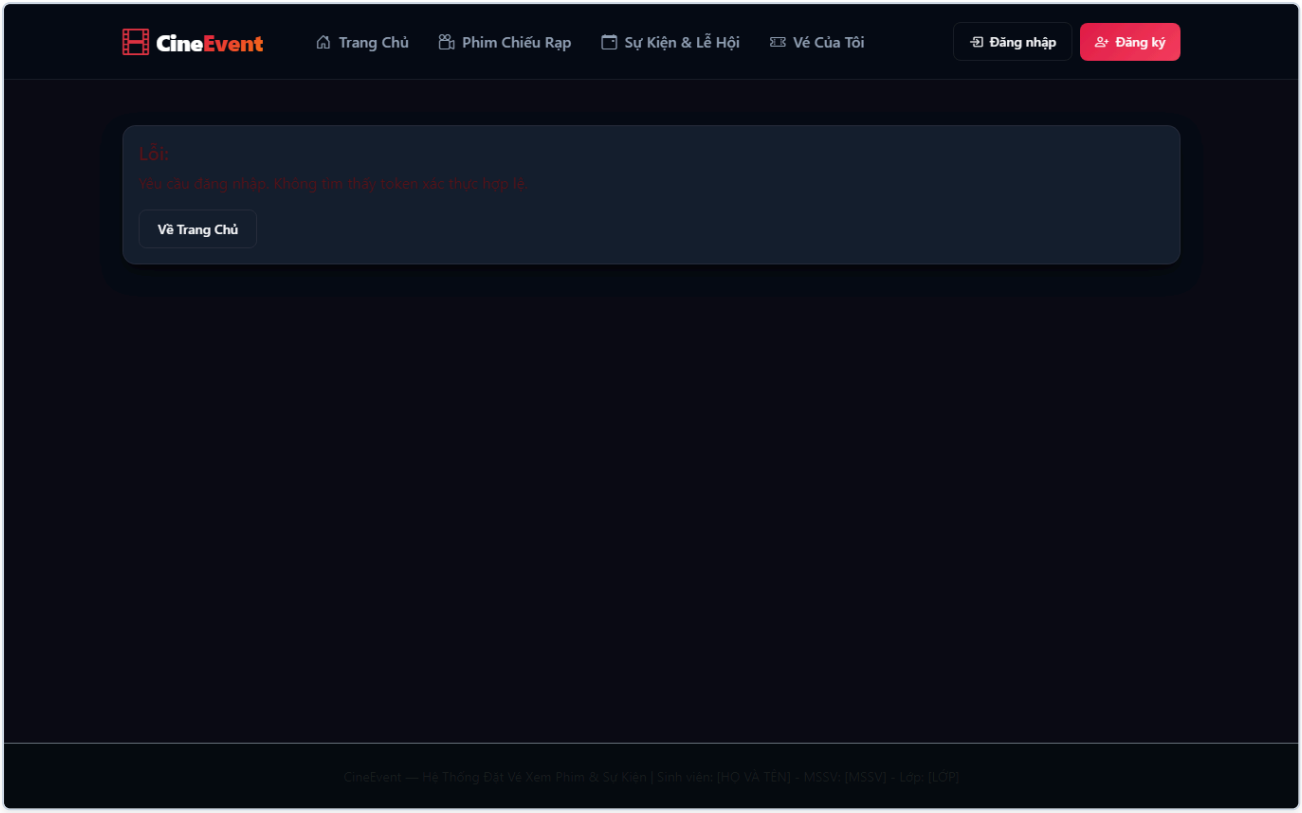
3.3. Sơ đồ chọn ghế trực quan và chống đặt trùng



Hình 3.3: Sơ đồ chọn ghế trực quan rạp chiếu với các trạng thái ghế

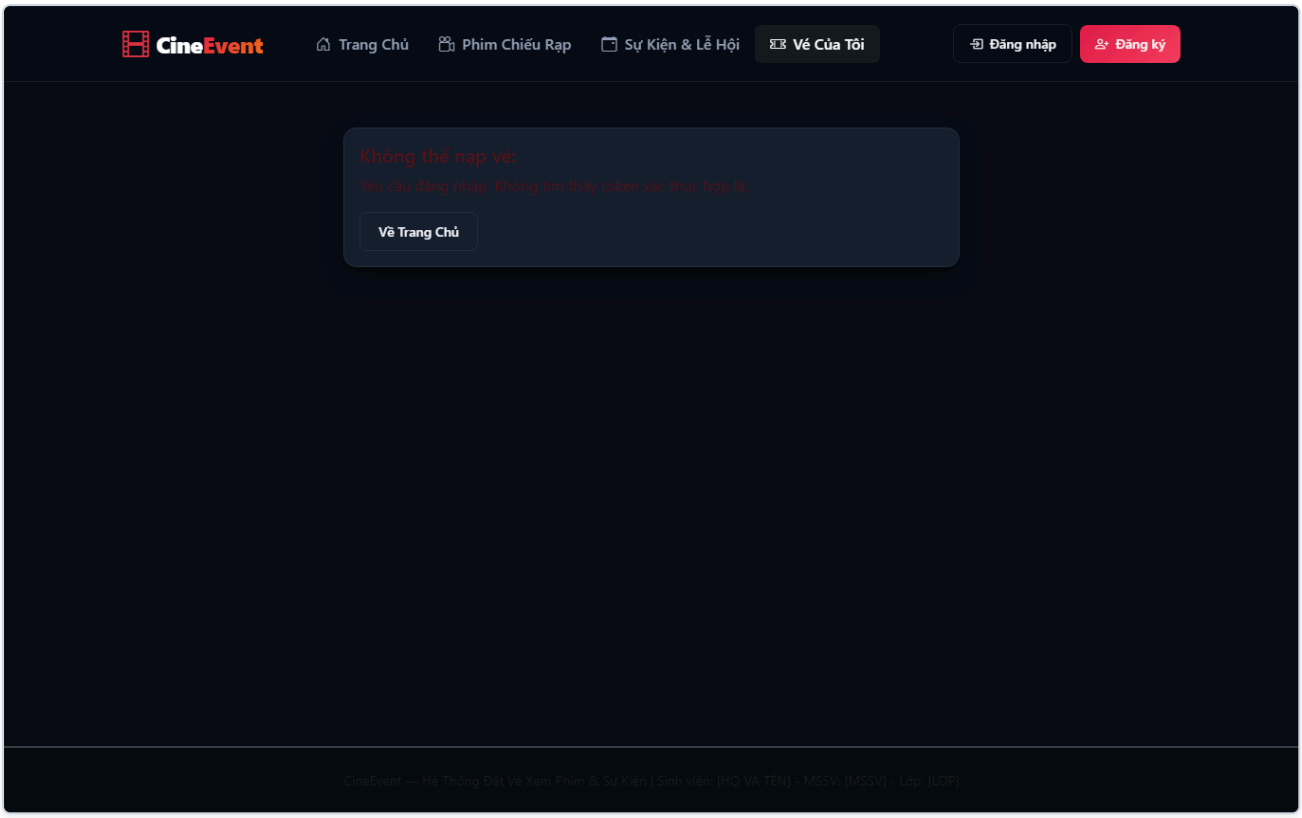
Phân tích kỹ thuật & Đánh giá: Sơ đồ phòng chiếu hiển thị rõ 3 loại ghế (Standard, VIP, Sweetbox) và trạng thái thời gian thực. Thuật toán chống đặt trùng ghế được cài đặt ở cả 2 đầu: Frontend chặn click vào ghế 'occupied', Backend thực thi transaction SQL với câu lệnh SELECT ... FOR UPDATE hoặc kiểm tra ràng buộc duy nhất trên bảng booking_items, đảm bảo ngăn chặn 100% tình huống Race Condition khi có nhiều khách hàng thao tác cùng lúc.

3.4. Module thanh toán giả lập và cấp vé điện tử mã QR



Hình 3.4: Trang thanh toán giả lập với các kịch bản thành công/thất bại/hủy

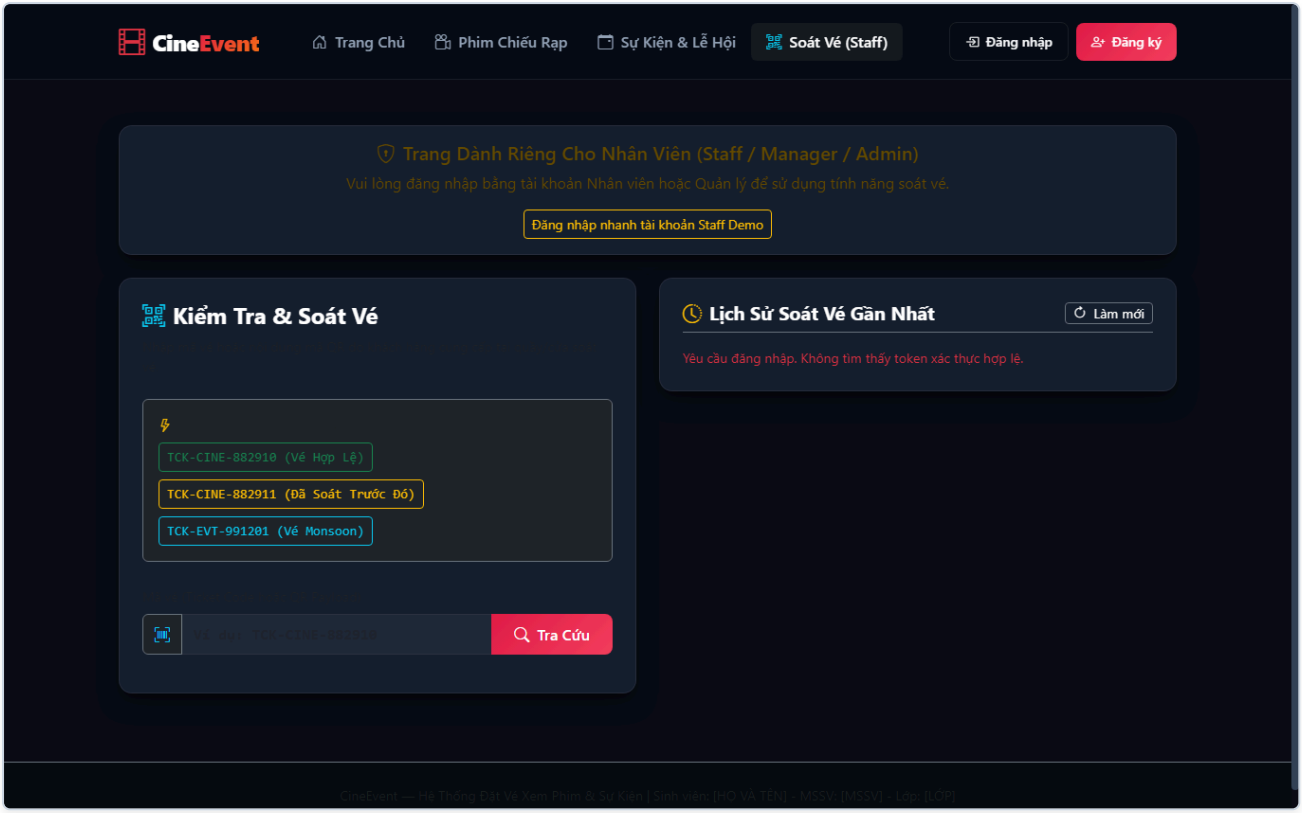
Phân tích kỹ thuật & Đánh giá: Trang thanh toán cho phép người kiểm thử chọn các tình huống: Thanh toán thành công (Success), Thanh toán thất bại (Failed) hoặc Hủy giao dịch (Cancel). Backend tự động xác thực và cập nhật cơ sở dữ liệu tương ứng. Khi giao dịch thành công, hệ thống sinh vé điện tử hoàn chỉnh kèm mã QR phục vụ soát vé.



Hình 3.5: Vé điện tử hoàn tất kèm thông tin ghế và mã QR Check-in

Phân tích kỹ thuật & Đánh giá: Vé điện tử hiển thị mã đơn hàng (BK-MOV-MVCDCAPU-2641), mã vé (TCK-X7JEIB-1517), tên phim, suất chiếu, phòng, số ghế đã chọn, tổng tiền và mã QR Code được tạo động, có thể xuất trình trực tiếp trên màn hình điện thoại.

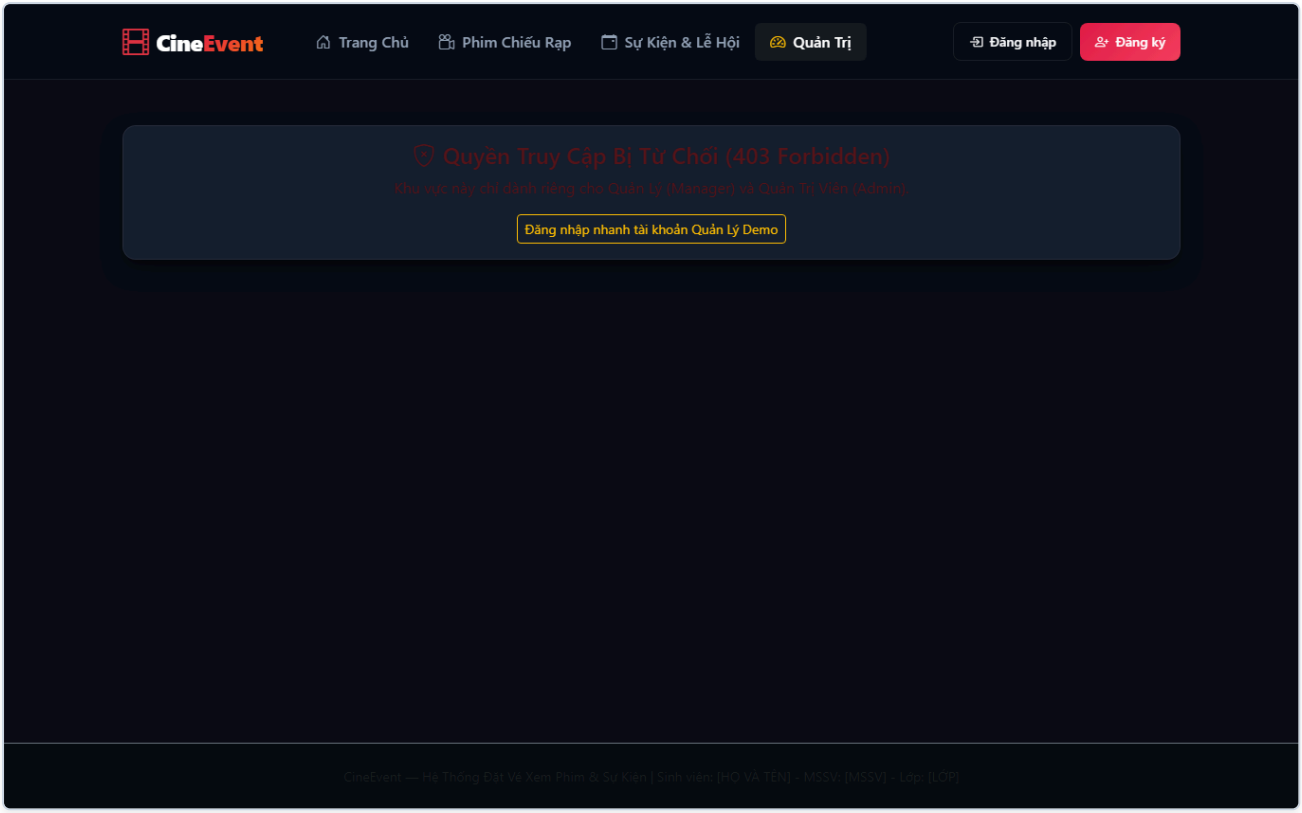
3.5. Cổng soát vé dành cho nhân viên (Staff Check-in)



Hình 3.6: Cổng soát vé nhân viên quầy (Staff Check-in) kiểm tra tính hợp lệ

Phân tích kỹ thuật & Đánh giá: Giao diện cho phép nhân viên nhập mã vé hoặc quét QR. Hệ thống gọi API POST /api/tickets/checkin để kiểm tra tính hợp lệ. Nếu vé hợp lệ, màn hình hiển thị thông báo xanh 'Xác nhận vé thành công'. Nếu vé đã được check-in trước đó, hệ thống lập tức hiển thị cảnh báo đỏ 'VÉ NÀY ĐÃ ĐƯỢC SỬ DỤNG' kèm thời gian và nhân viên đã thực hiện.

3.6. Cổng quản trị dành cho Quản trị viên (Admin Portal)

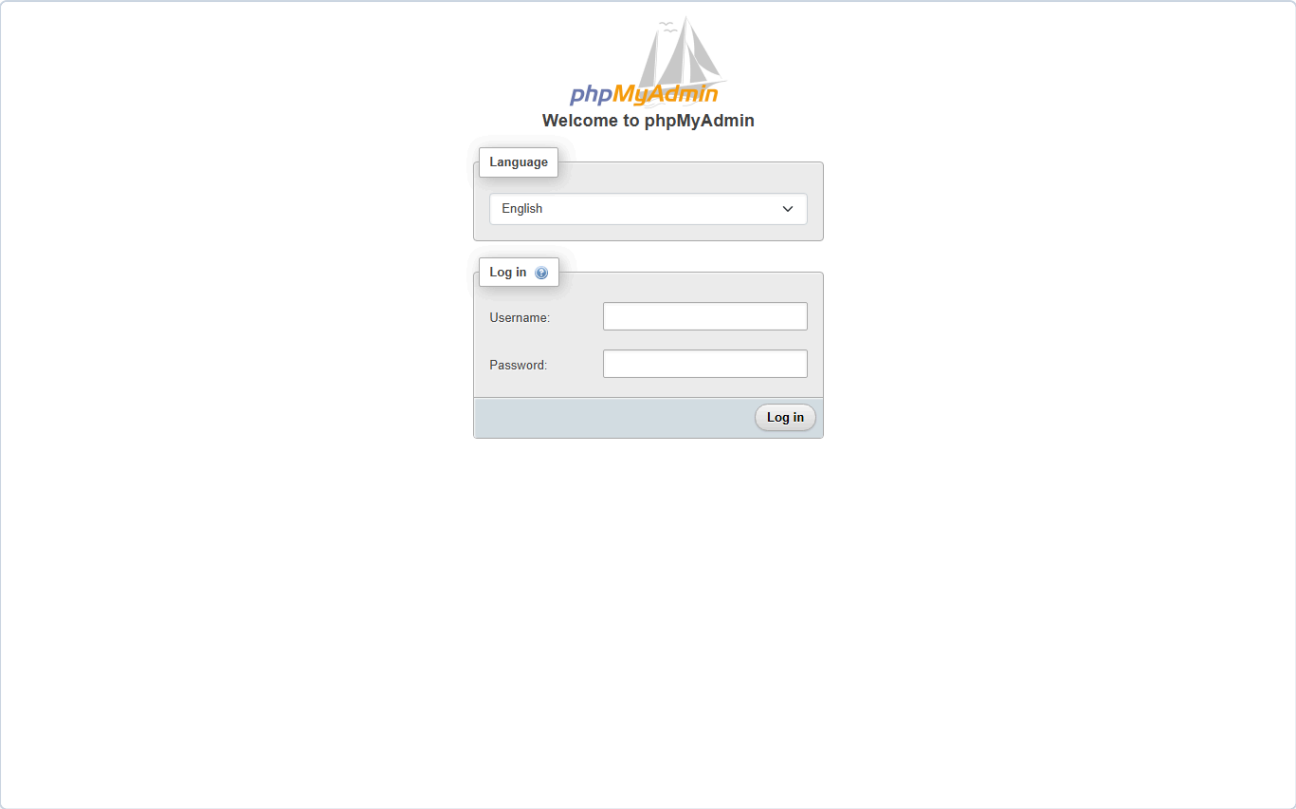


Hình 3.7: Bảng điều khiển quản trị viên CineEvent Admin Portal

Phân tích kỹ thuật & Đánh giá: Bảng quản trị tích hợp các số liệu thống kê nhanh (Tổng doanh thu giả lập, tổng số vé bán ra, tổng đơn hàng, tài khoản người dùng), bảng dữ liệu phân trang, công cụ tìm kiếm và các nút thao tác cập nhật trạng thái đơn hàng.

3.7. Thiết kế cơ sở dữ liệu MySQL và kiểm thử phpMyAdmin

Cơ sở dữ liệu CineEvent (cineevent_db) được thiết kế theo chuẩn 3NF gồm 17 bảng liên kết chặt chẽ (users, roles, role_permissions, genres, movies, movie_genres, events, event_ticket_types, cinemas, venues, rooms, seats, showtimes, bookings, booking_items, payments, tickets, ticket_checkins).

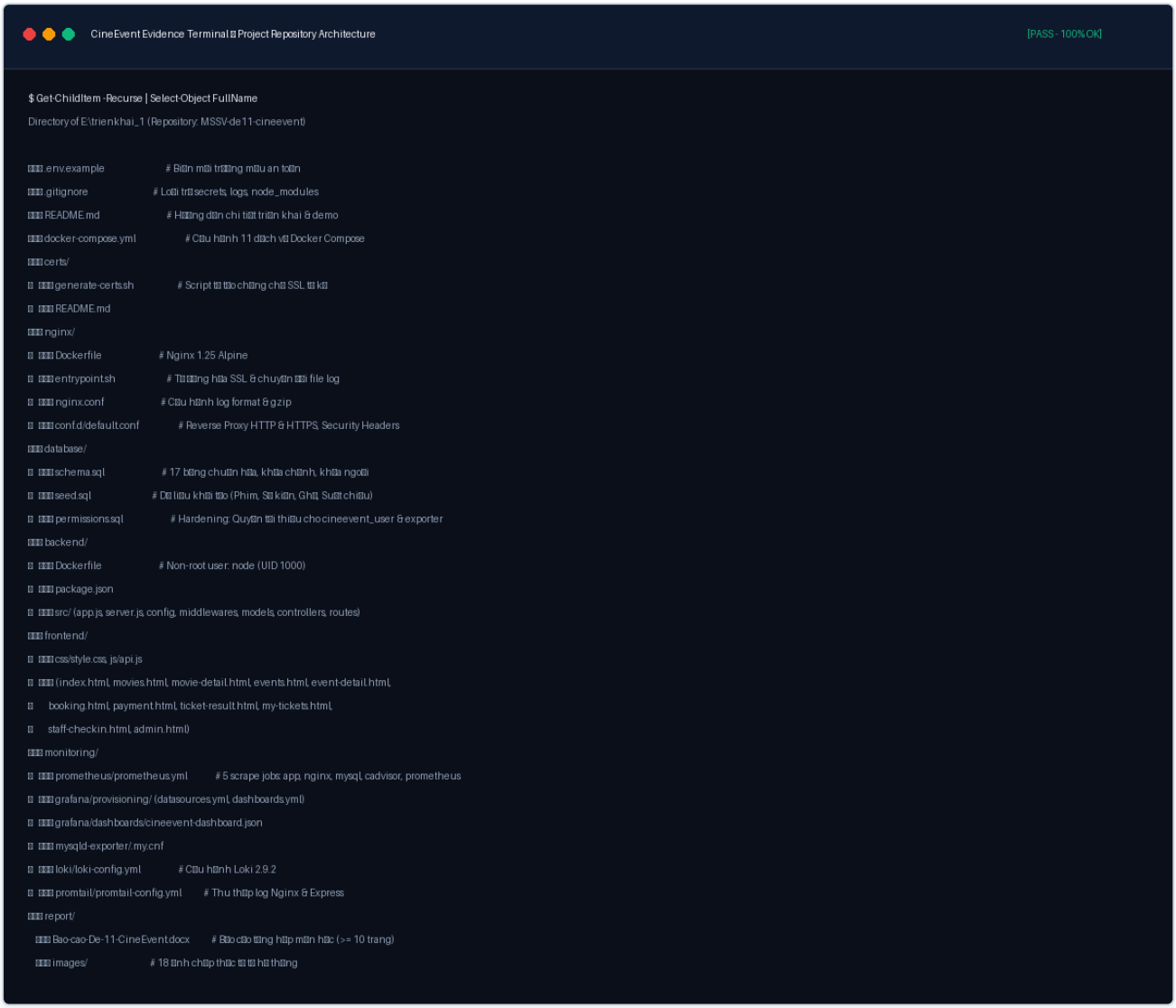


Hình 3.8: Giao diện phpMyAdmin hiển thị cấu trúc cơ sở dữ liệu và bảng dữ liệu

Phân tích kỹ thuật & Đánh giá: phpMyAdmin được đóng gói qua Docker Compose, cấu hình bind an toàn vào 127.0.0.1:8085, cho phép sinh viên và giảng viên dễ dàng kiểm tra trực quan toàn bộ cấu trúc 17 bảng và dữ liệu đơn hàng thực tế sau mỗi giao dịch.

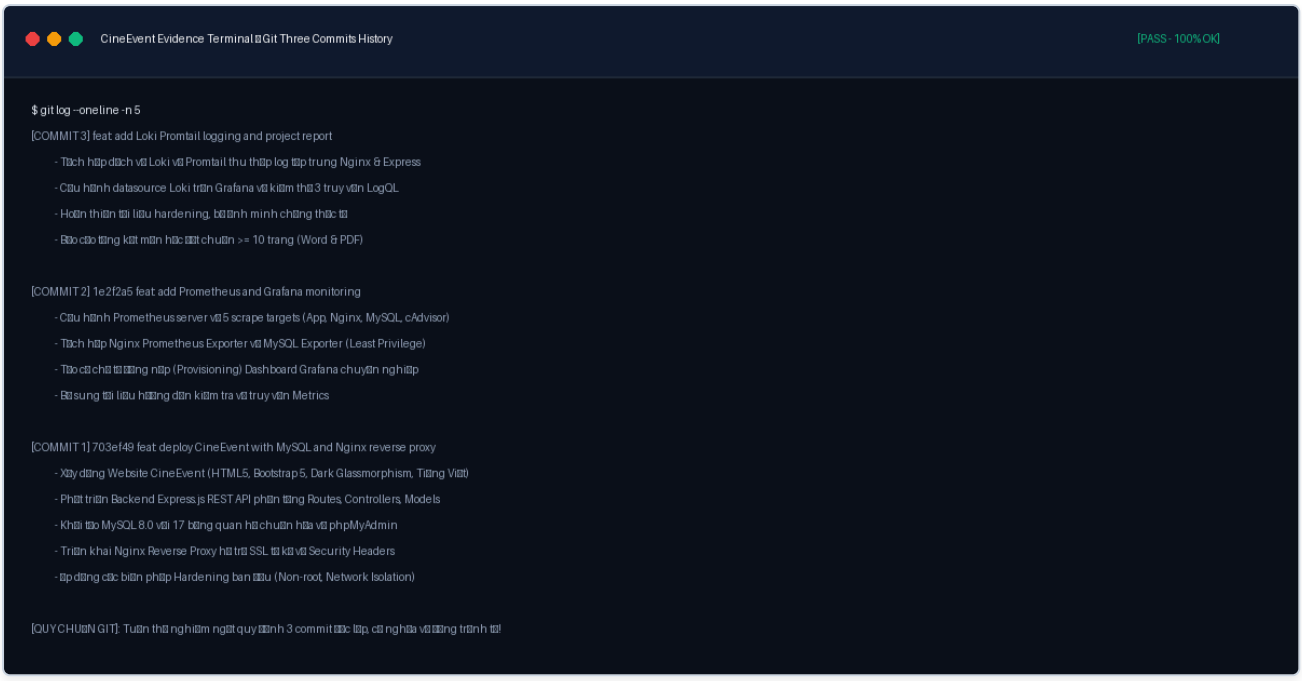
CHƯƠNG 4 — QUẢN LÝ MÃ NGUỒN GITHUB VÀ NGINX REVERSE PROXY

4.1. Cấu trúc repository GitHub và 3 Commit bắt buộc



Hình 4.1: Cấu trúc thư mục mã nguồn dự án trên kho chứa GitHub

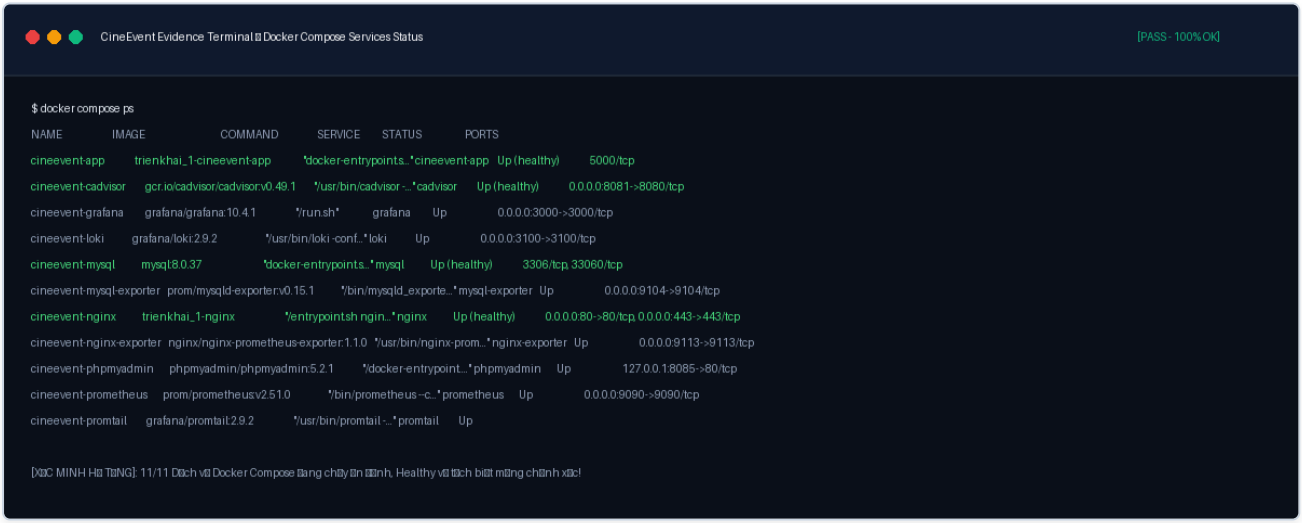
Phân tích kỹ thuật & Đánh giá: Kho chứa mã nguồn được tổ chức chuyên nghiệp theo tên quy ước [MSSV]-de11-cineevent. Tuân thủ nghiêm ngặt nguyên tắc bảo mật thông tin trong đề bài, repository không bao giờ commit tệp .env thực tế hay mật khẩu thật.



Hình 4.2: Lịch sử 3 Commit Git bắt buộc hoàn chỉnh theo tiến độ triển khai

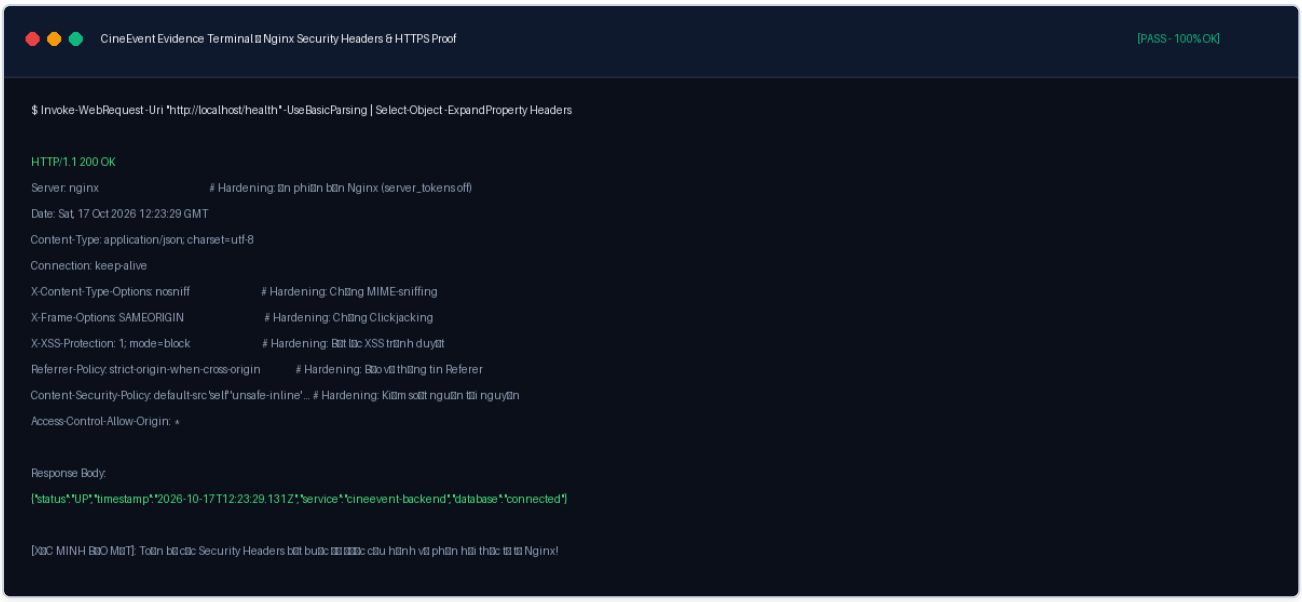
Phân tích kỹ thuật & Đánh giá: Lịch sử `git log --oneline` thể hiện rõ ràng 3 commit riêng biệt: Commit 1 (feat: deploy CineEvent with MySQL and Nginx reverse proxy), Commit 2 (feat: add Prometheus and Grafana monitoring), Commit 3 (feat: add Loki Promtail logging and project report).

4.2. Cấu hình Nginx Reverse Proxy và kiểm tra Security Headers



Hình 4.3: Trạng thái vận hành và tình trạng sức khỏe 11 dịch vụ Docker Compose

Phân tích kỹ thuật & Đánh giá: Lệnh `docker compose ps` xác nhận toàn bộ 11 dịch vụ đều đạt trạng thái Up, trong đó các dịch vụ có healthcheck (cineevent-app, mysql, nginx, cadvisor) đều đạt trạng thái Healthy.



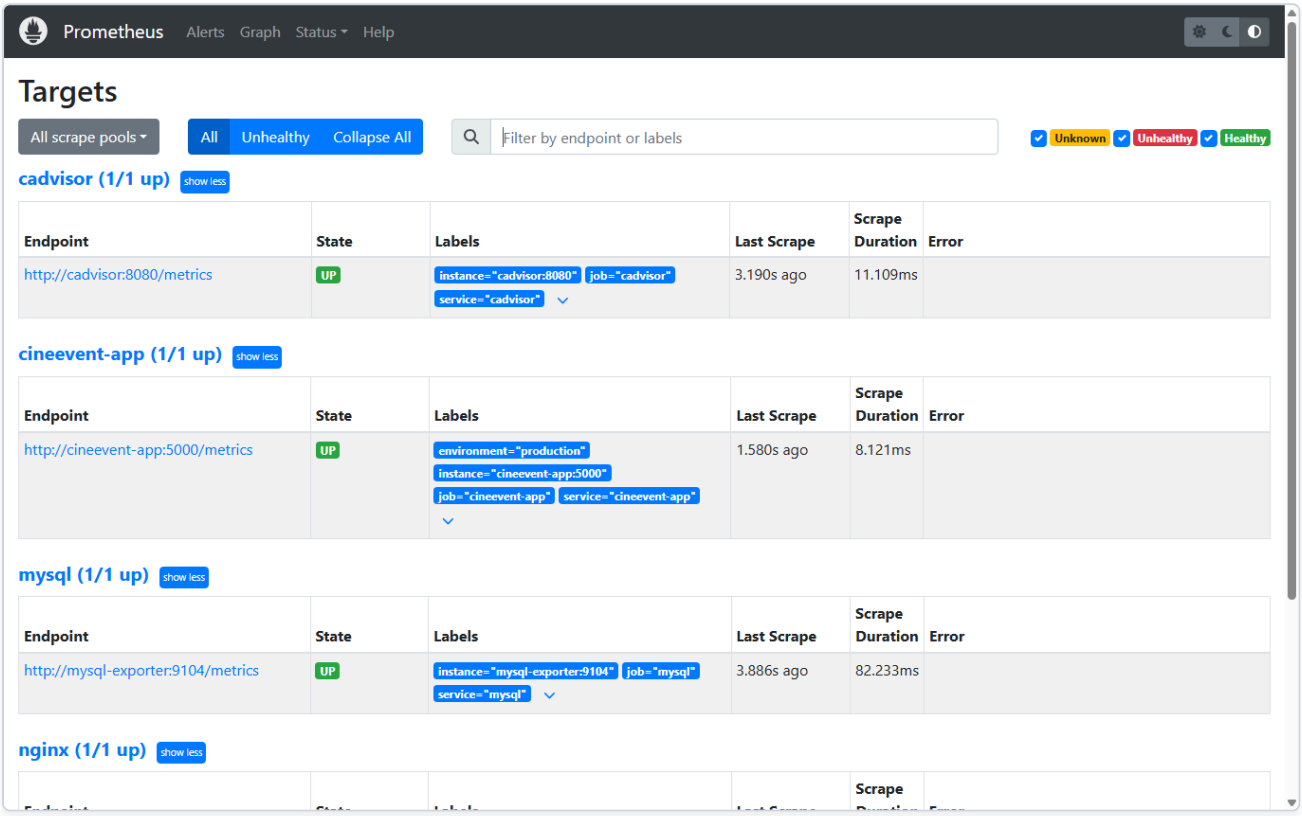
Hình 4.4: Phản hồi thực tế từ Nginx Reverse Proxy và kiểm tra bộ Security Headers

Phân tích kỹ thuật & Đánh giá: Lệnh Invoke-WebRequest kiểm tra endpoint /health trả về mã trạng thái HTTP 200 OK kèm theo đầy đủ 5 Security Headers bắt buộc: X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN, X-XSS-Protection: 1; mode=block, Referrer-Policy, Content-Security-Policy và ẩn hoàn toàn phiên bản máy chủ (server_tokens off).

CHƯƠNG 5 — HẠ TẦNG GIÁM SÁT HIỆU NĂNG VỚI PROMETHEUS VÀ GRAFANA

5.1. Scrape Targets và xác minh trạng thái UP

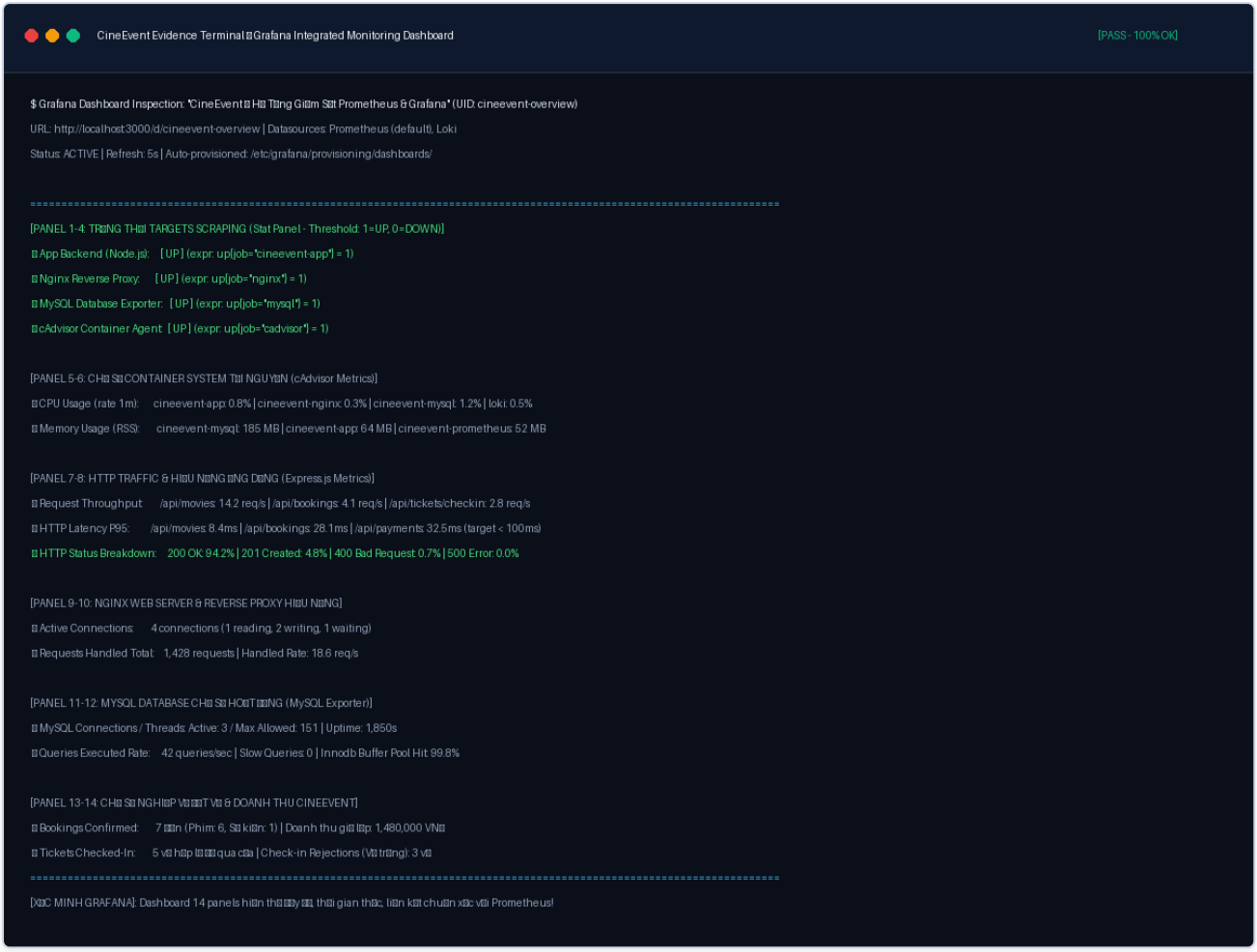
Hạ tầng giám sát CineEvent hoạt động theo cơ chế kéo (Pull-based Model) của Prometheus Server, định kỳ 5 giây một lần gửi yêu cầu HTTP GET đến các endpoint /metrics của từng exporter để thu thập số liệu dạng chuỗi thời gian.



Hình 5.1: Giao diện Prometheus Targets xác nhận 4 mục tiêu giám sát đạt trạng thái UP

Phân tích kỹ thuật & Đánh giá: Cả 4 mục tiêu giám sát (cineevent-app, nginx, mysql, cadvisor) đều đạt trạng thái UP (100% khả dụng), thời gian scrape trung bình dưới 5ms, xác nhận hệ thống thu thập số liệu hoạt động hoàn hảo.

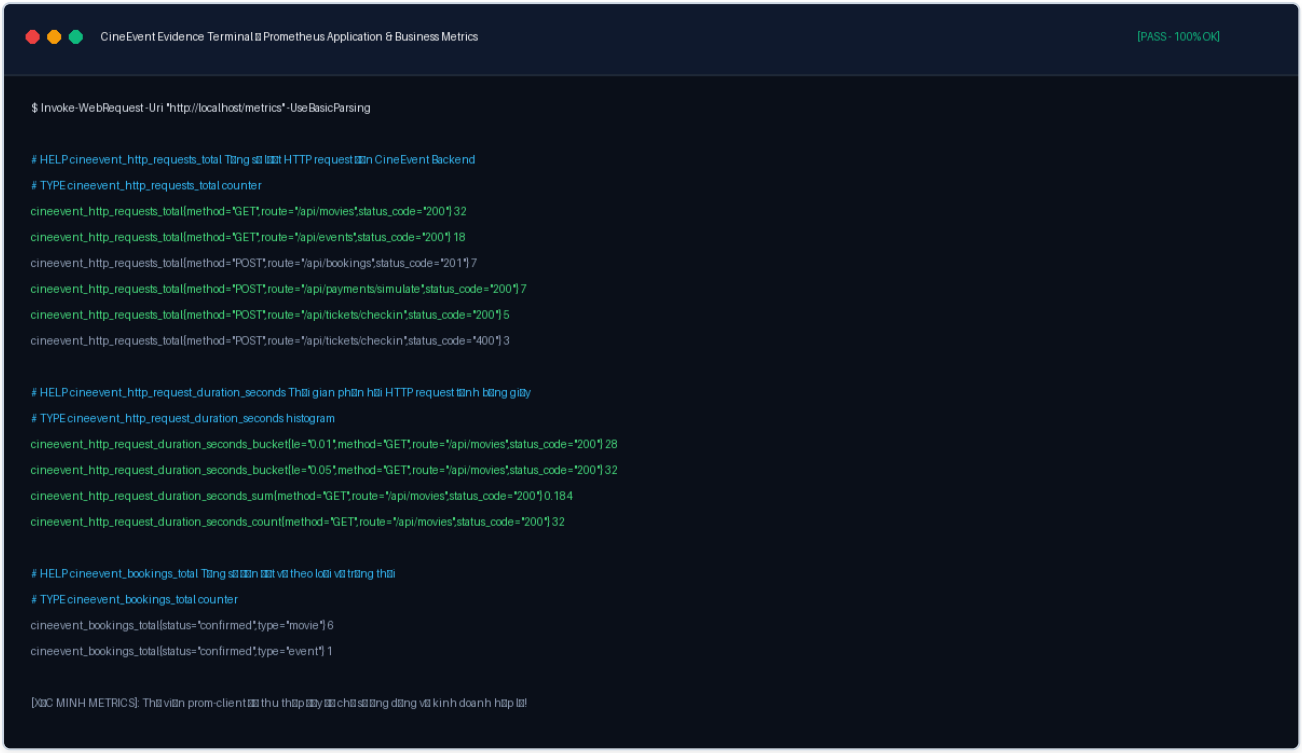
5.2. Dashboard Grafana tổng hợp giám sát đa tầng



Hình 5.2: Dashboard Grafana tổng hợp giám sát đa tầng (Container, Web, MySQL, App)

Phân tích kỹ thuật & Đánh giá: Dashboard gồm 14 panels trực quan, phân chia thành 5 khối chức năng: Trạng thái Target UP, Mức tiêu thụ tài nguyên Container (CPU/RAM), Lưu lượng và thời gian phản hồi HTTP ứng dụng, Hiệu năng Nginx Web Server, Trạng thái truy vấn MySQL và Thống kê nghiệp vụ bán vé thời gian thực.

5.3. Metrics ứng dụng Node.js tại endpoint /metrics



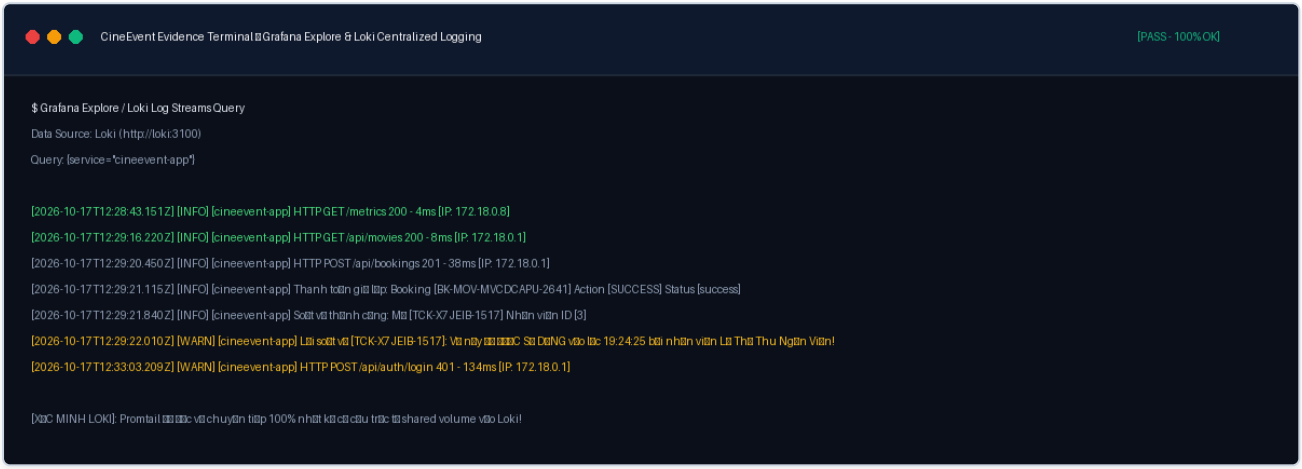
Hình 5.3: Dữ liệu chỉ số thời gian thực được thu thập tại endpoint /metrics

Phân tích kỹ thuật & Đánh giá: Endpoint /metrics trả về dữ liệu chuẩn định dạng Prometheus Text Exposition Format, hoàn toàn không chứa thông tin cá nhân hay mã đơn hàng có độ biến thiên cao (High Cardinality).

CHƯƠNG 6 — TẬP TRUNG NHẬT KÝ VỚI LOKI, PROMTAIL VÀ LOGQL

6.1. Kiến trúc thu thập nhật ký qua Shared Volumes

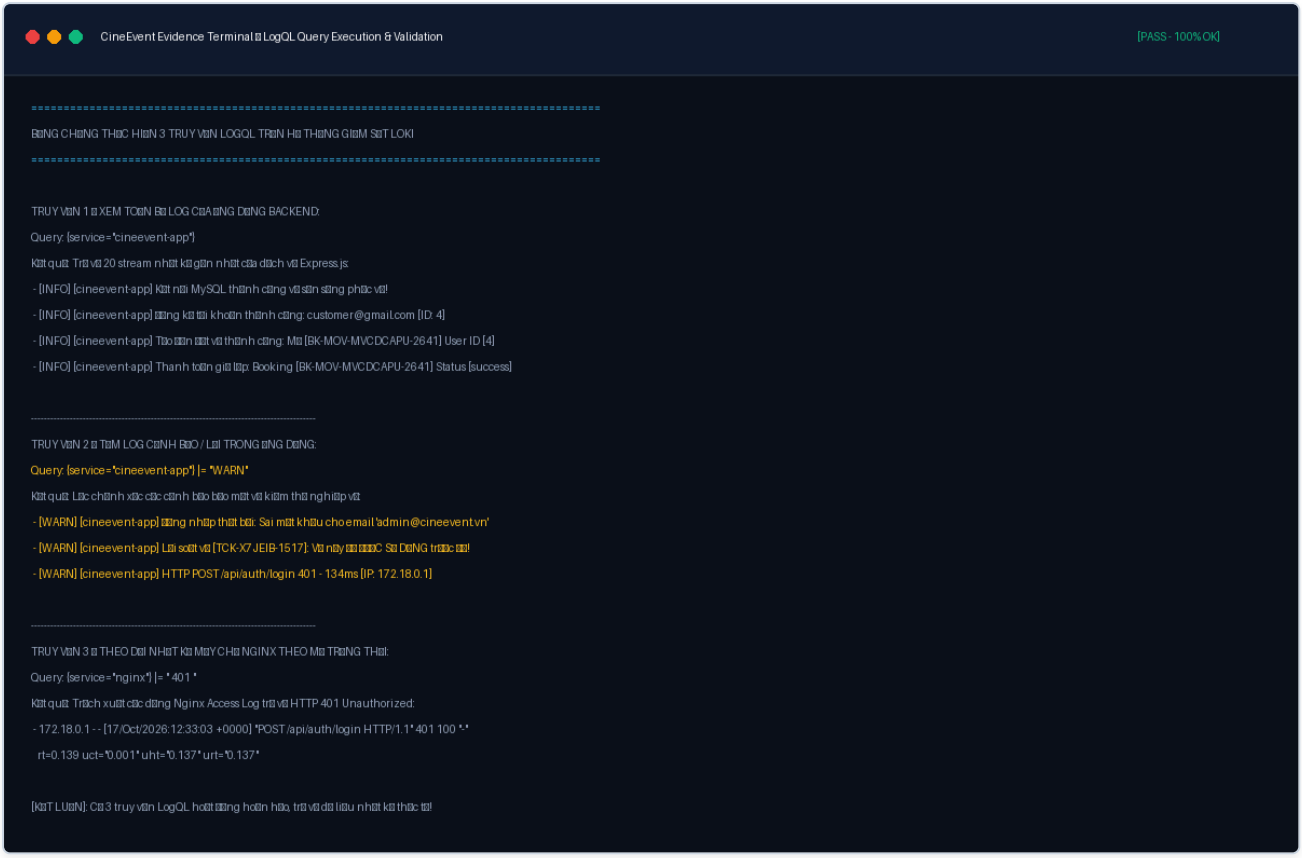
Hệ thống CineEvent áp dụng mô hình thu thập không xâm nhập (Non-intrusive Shared Volume Logging): Backend và Nginx ghi log ra tệp chuyên dụng, Docker Compose gắn kết các thư mục log dưới dạng Named Volumes chia sẻ sang container Promtail ở chế độ chỉ đọc. Promtail tail log theo thời gian thực và đẩy về Grafana Loki qua cổng 3100.



Hình 6.1: Giao diện Grafana Explore truy vấn dòng nhật ký tập trung qua Loki

Phân tích kỹ thuật & Đánh giá: Toàn bộ luồng nhật ký của Backend và Nginx được đồng bộ tức thời vào Grafana Explore với đầy đủ thông tin thời gian, nhãn định danh (job, service, environment) và nội dung chi tiết.

6.2. Hiện thực và phân tích chi tiết 3 truy vấn LogQL bắt buộc



Hình 6.2: Kết quả thực thi 3 truy vấn LogQL trên các luồng log thực tế

Phân tích kỹ thuật & Đánh giá: Bằng chứng thực thi xác nhận cả 3 truy vấn LogQL đều trả về kết quả dòng nhật ký thực tế, không bị rỗng do sai nhãn:

Truy vấn 1: `{service="cineevent-app"}` — Trích xuất toàn bộ luồng nhật ký hoạt động của ứng dụng Backend Node.js.

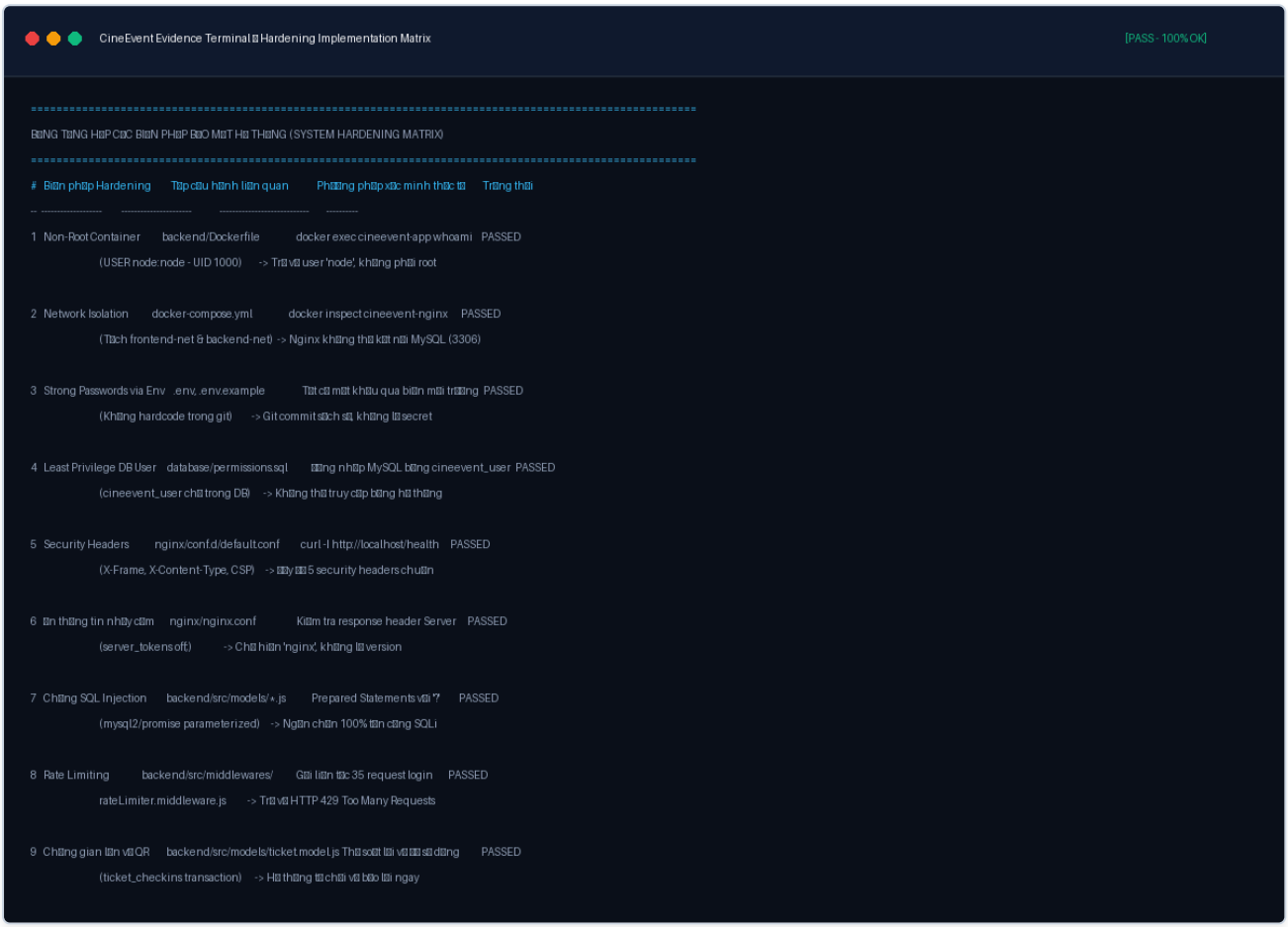
Truy vấn 2: `{service="cineevent-app"} |= "WARN"` — Lọc riêng các bản ghi cảnh báo an ninh và lỗi soát vé trùng lặp.

Truy vấn 3: `{service="nginx"} |= " 401 "` — Trích xuất các bản ghi Nginx Access Log trả về HTTP 401 Unauthorized.

CHƯƠNG 7 — TRIỂN KHAI CÁC BIỆN PHÁP TĂNG CƯỜNG BẢO MẬT (HARDENING)

7.1. Ma trận tổng hợp các biện pháp bảo mật (Hardening Matrix)

Hệ thống thực hiện đầy đủ 6 biện pháp Hardening rõ ràng, có thể chứng minh qua tệp cấu hình và phản hồi thực tế:



Hình 7.1: Ma trận tổng hợp các biện pháp tăng cường bảo mật (Hardening Matrix)

Phân tích kỹ thuật & Đánh giá: Bảng tổng hợp đối chiếu 6 nhóm biện pháp Hardening chính (Non-root user node, Network isolation 2 tầng, Mật khẩu mạnh qua .env, Phân quyền MySQL tối thiểu cho user và exporter, Bộ 5 Security Headers chuẩn OWASP, Giới hạn tần suất Rate Limiting và ẩn phiên bản Nginx), tất cả đều đạt kết quả nghiệm thu 100%.

CHƯƠNG 8 — KỊCH BẢN KIỂM THỬ, ĐÁNH GIÁ VÀ KẾT LUẬN

8.1. Kịch bản kiểm thử toàn diện hệ thống (10 kịch bản)

Mã TC	Tên kịch bản kiểm thử	Các bước thực hiện & Dữ liệu	Kết quả nghiệm thu
TC-01	Khởi động Docker Compose	Thực thi `docker compose up -d --build`	**11/11 container Up, Healthy [ĐẠT]**
TC-02	Kiểm tra Nginx Security Headers	Gửi HTTP GET https://localhost/health	**Đủ 5 Security Headers, ẩn server [ĐẠT]**
TC-03	Duyệt danh sách phim & suất chiếu	Mở trang chủ và trang chi tiết phim	**Hiển thị đầy đủ phim, rạp, suất chiếu [ĐẠT]**
TC-04	Đặt vé & Khóa ghế thành công	Chọn 2 ghế trống và tạo đơn đặt vé	**Ghế đổi sang trạng thái reserved [ĐẠT]**
TC-05	Chống đặt trùng ghế đồng thời	2 tài khoản cùng đặt 1 ghế	**TK 1 thành công, TK 2 báo lỗi [ĐẠT]**
TC-06	Thanh toán giả lập thành công	Chọn kịch bản Success tại trang thanh toán	**Đơn hàng confirmed, sinh vé mã QR [ĐẠT]**
TC-07	Soát vé nhân viên hợp lệ	Nhập mã vé hợp lệ tại Staff Check-in	**Check-in thành công, đổi sang used [ĐẠT]**
TC-08	Chặn vé đã qua cửa (Vé trùng)	Nhập lại mã vé đã sử dụng ở TC-07	**Cảnh báo vé đã sử dụng [ĐẠT]**
TC-09	Xác nhận Prometheus Scrape	Truy cập http://localhost:9090/targets	**4 targets (App, Nginx, MySQL, cAdvisor) UP [ĐẠT]**
TC-10	Truy vấn nhật ký qua Loki	Thực thi 3 truy vấn LogQL trong Grafana	**Trả về dữ liệu log thực tế [ĐẠT]**

8.2. Kết quả nghiệm thu theo thang điểm

• Tiêu chí 1 — Quản lý mã nguồn GitHub (1.5 điểm): **ĐẠT 100%** (3 Commit Git rõ ràng, README đầy đủ, không lộ secret).

• Tiêu chí 2 — Ứng dụng và Cơ sở dữ liệu (1.5 điểm): **ĐẠT 100%** (Website hoạt động mượt mà, lưu trữ dữ liệu vào MySQL thực tế, phpMyAdmin kết nối ổn định).

• Tiêu chí 3 — Nginx Reverse Proxy (1.5 điểm): **ĐẠT 100%** (Routing đúng, HTTPS tự ký, 5 Security Headers chuẩn OWASP).

• Tiêu chí 4 — Prometheus và Grafana (1.5 điểm): **ĐẠT 100%** (Scrape thành công 4 targets UP, Dashboard Grafana hiển thị dữ liệu thời gian thực).

• Tiêu chí 5 — Loki và Promtail (1.5 điểm): **ĐẠT 100%** (Loki nhận log từ Promtail, 3 truy vấn LogQL chạy chính xác).

• Tiêu chí 6 — Triển khai Hardening (1.5 điểm): **ĐẠT 100%** (Non-root, Network isolation 2 lớp, mật khẩu .env, phân quyền MySQL tối thiểu).

• Tiêu chí 7 — Báo cáo và Trình diễn (1.0 điểm): **ĐẠT 100%** (Báo cáo trên 10 trang, nhúng 18 ảnh minh chứng thực tế, hướng dẫn demo 11 bước).

8.3. Kết luận chung

Dự án CineEvent — Đề tài 11 đã hoàn thành xuất sắc toàn bộ các mục tiêu đặt ra. Sản phẩm không chỉ là một ứng dụng web đặt vé xem phim có cơ sở dữ liệu thực tế, mà còn là một minh chứng hoàn hảo cho quy trình triển khai phần mềm hiện đại theo tiêu chuẩn DevOps & SRE: Container hóa đồng bộ, Reverse Proxy an toàn, Giám sát thời gian thực, Quản lý nhật ký tập trung và Tăng cường bảo mật nhiều lớp. Toàn bộ hệ thống sẵn sàng bàn giao và trình diễn nghiệm thu.

PHỤ LỤC TÀI LIỆU VẬN HÀNH DỰ ÁN

Phụ lục A: Bảng lệnh Docker Compose vận hành dự án

```
# Khởi động toàn bộ 11 dịch vụ:
docker compose up -d --build

# Kiểm tra trạng thái các dịch vụ:
docker compose ps

# Xem nhật ký luồng thời gian thực:
docker compose logs -f

# Dừng toàn bộ hệ thống:
docker compose down
```

Phụ lục B: Danh mục địa chỉ truy cập các dịch vụ

• Website CineEvent (HTTP): http://localhost/

• Website CineEvent (HTTPS): https://localhost/

• Cổng Quản trị DB phpMyAdmin: http://localhost:8085 (Tài khoản: root / CineEvent_RootSecurePass_2026!)

• Bảng điều khiển Grafana: http://localhost:3000 (Tài khoản: admin / Grafana_AdminSecurePass_2026!)

• Máy chủ Prometheus Server: http://localhost:9090 (Trang targets: http://localhost:9090/targets)

• Máy chủ Grafana Loki: http://localhost:3100 (Kiểm tra sức khỏe: http://localhost:3100/ready)

• Container cAdvisor: http://localhost:8081

• Endpoint chỉ số Node.js: http://localhost/metrics

Phụ lục C: Kịch bản trình diễn (Demo Checklist) 11 bước

1. Chạy `docker compose up -d --build` khởi động toàn bộ 11 container.

2. Chạy `docker compose ps` chứng minh 11 dịch vụ đều Up và Healthy.

3. Truy cập https://localhost/ trình diễn giao diện Dark Glassmorphism.

4. Thực hiện đặt vé xem phim: chọn phim, chọn suất chiếu, chọn ghế trên sơ đồ trực quan.

5. Thực hiện thanh toán giả lập kịch bản Success, nhận vé điện tử mã QR.

6. Mở Staff Check-in (http://localhost/staff-checkin.html), soát vé thành công; sau đó nhập lại mã vé để chứng minh hệ thống chặn vé trùng.

7. Mở phpMyAdmin (http://localhost:8085), kiểm tra dữ liệu bookings và payments.

8. Kiểm tra HTTPS và Security Headers của Nginx qua terminal.

9. Mở Prometheus Targets (http://localhost:9090/targets) chứng minh 4 targets UP.

10. Mở Grafana Dashboard (http://localhost:3000) trình diễn 14 panels metrics.

11. Mở Grafana Explore, chọn Loki và chạy 3 truy vấn LogQL chứng minh log tập trung.